

MODULE 08 · DOMAIN 2 - SECURITY AND COMPLIANCE

Protection, Encryption and Secrets

The services that stop things, and the ones that keep data unreadable.

DOMAIN 2 of 4 EXAM WEIGHT 30% MODULE 8 of 26

Protection acts at a **layer**. Identify the layer and the service picks itself.

The protection line-up

SERVICE	WHAT IT STOPS
AWS Shield	Volumetric DDoS at the network and transport layers
AWS WAF	Malicious HTTP requests at the application layer
AWS Firewall Manager	Nothing itself. It applies WAF and Shield rules across many accounts
Security groups	Traffic reaching an instance. Stateful, allow rules only
Network ACLs	Traffic entering a subnet. Stateless, allow and deny

ON THE EXAM

Firewall Manager is the odd one out. It is a management layer, not a protection mechanism.

Shield or WAF?

AWS SHIELD

How much traffic

- DDoS protection at layers 3 and 4
- Standard is free and automatic for everyone
- Absorbs floods; never reads a request
- Advanced adds response team and cost protection

AWS WAF

What the traffic says

- Filters HTTP and HTTPS at layer 7
- Rules for SQL injection, cross-site scripting, IP, geography
- Reads and judges every request
- Attaches to CloudFront, ALB, API Gateway

THE TIEBREAKER

Flooding means Shield. Inspecting the request means WAF. They frequently protect the same load balancer together.

Shield Standard or Shield Advanced?

SHIELD STANDARD

Already on, costs nothing

- Automatic for every AWS customer
- No configuration and no charge
- Common network and transport layer attacks
- You cannot switch it off or opt in

SHIELD ADVANCED

Paid subscription

- \$3,000 per month, one-year commitment
- Access to the Shield Response Team
- Cost protection for scaling during an attack
- Covers standard WAF costs on protected resources

WORTH KNOWING

Reaching the Shield Response Team also requires Business or Enterprise Support. Advanced alone is not enough.

AWS WAF in practice

- ◆ **A web ACL holds rules** that allow, block or count requests before they reach your application.
- ◆ AWS managed rule groups cover common threats without you writing anything.
- ◆ **Rate-based rules** block an address sending more than a threshold of requests, which handles crude flooding at layer 7.
- ◆ It attaches to CloudFront, Application Load Balancer, API Gateway and AppSync.
- ◆ It cannot protect an EC2 instance directly. Something must sit in front of it.

ON THE EXAM

Geographic restriction, SQL injection and cross-site scripting are all WAF, not Shield and not security groups.

AWS Firewall Manager

- ◆ It **applies protection policies centrally** across every account in an organisation.
- ◆ New accounts and new resources inherit the rules automatically as they appear.
- ◆ It manages WAF web ACLs, Shield Advanced protections and security group policies.
- ◆ It requires AWS Organizations. It is not for a single account.
- ◆ AWS Network Firewall is a different service, and it is not on the CLF-C02 in-scope list.

ON THE EXAM

One account means WAF directly. Many accounts needing the same rules consistently means Firewall Manager.

Encryption does not stop a breach. It makes the stolen data **worthless**.

At rest or in transit?

ENCRYPTION AT REST

Data sitting on disk

- S3 objects, EBS volumes, RDS storage, snapshots
- Keys usually managed through AWS KMS
- You choose to enable it
- Protects against stolen storage

ENCRYPTION IN TRANSIT

Data moving over a network

- TLS between client and service
- Certificates issued by AWS Certificate Manager
- Enabled on endpoints and load balancers
- Protects against interception

THE TIEBREAKER

At rest means storage and KMS. In transit means TLS and certificates. The two use different services entirely.

AWS Key Management Service

- ◆ **KMS creates, stores and controls the keys** that encrypt data across most AWS services.
- ◆ Keys never leave KMS unencrypted. You call KMS to encrypt and decrypt rather than handling key material.
- ◆ **Customer managed keys** are ones you create and control, with your own key policy and rotation.
- ◆ AWS managed keys are created for you per service and require no administration.
- ◆ Every key use is recorded in AWS CloudTrail, which is how you audit who decrypted what.

ON THE EXAM

KMS is the default answer for encryption keys. Reach for CloudHSM only when the question demands dedicated hardware.

KMS or CloudHSM?

AWS KMS

Managed and multi-tenant

- AWS operates the hardware
- Integrated with most AWS services
- Simplest and cheapest option
- The right answer unless told otherwise

AWS CLOUDHSM

Dedicated hardware, yours alone

- Single-tenant hardware security modules
- You have exclusive control; AWS cannot access your keys
- FIPS 140-2 Level 3 validated
- For regulations demanding you control the HSM

THE TIEBREAKER

Only choose CloudHSM when the scenario names a regulatory need for dedicated, single-tenant hardware.

AWS Certificate Manager

- ◆ **Provisions and manages TLS certificates** for AWS services.
- ◆ Public certificates are free when used with integrated services such as CloudFront and Elastic Load Balancing.
- ◆ **It renews them automatically**, which removes the classic outage caused by an expired certificate.
- ◆ AWS Private CA issues private certificates for internal use.
- ◆ It secures data in transit only. It has nothing to do with encrypting stored data.

ON THE EXAM

An expired certificate causing an outage is the giveaway scenario. Automatic renewal is the ACM selling point.

Secrets Manager or Parameter Store?

AWS SECRETS MANAGER

Secrets that must rotate

- Built-in automatic rotation
- Native rotation for RDS, Redshift, DocumentDB
- Charged per secret per month
- Purpose-built for credentials

SSM PARAMETER STORE

Configuration and simple secrets

- Hierarchical configuration values
- SecureString encrypts with KMS
- Standard tier has no charge
- No built-in automatic rotation

THE TIEBREAKER

Automatic rotation means Secrets Manager. Free configuration storage means Parameter Store. That single word decides it.

Reverse lookup

IF THE SCENARIO SAYS	THE SERVICE IS
A flood of traffic overwhelming the application	AWS Shield
SQL injection, cross-site scripting, blocking a country	AWS WAF
Same rules applied across every account automatically	AWS Firewall Manager
Encrypt stored data, manage and audit keys	AWS KMS
Regulator requires dedicated single-tenant hardware	AWS CloudHSM
Certificates expiring and causing outages	AWS Certificate Manager
Database credentials that must rotate automatically	AWS Secrets Manager

ON THE EXAM

Seven phrases, seven services. Learn the phrases; the exam reuses them with very little variation.

A retailer's public website sits behind an Application Load Balancer. During a sale, the site becomes unreachable.

Analysis shows two things at once: a very large volume of meaningless packets saturating the connection, and a separate set of requests attempting SQL injection against the checkout form.

Which combination addresses both problems?

- ☐ A AWS WAF for both problems
- ☐ B Shield Standard is already handling the flood; add AWS WAF for the injection
- ☐ C Security groups for the flood; AWS Shield Advanced for the injection
- ☐ D Amazon GuardDuty for both problems

◆ PAUSE AND DECIDE

Which combination addresses both problems?

- A

 AWS WAF for both problems
WAF inspects request content but does not absorb volumetric attacks at layers 3 and 4.
- B

 Shield Standard is already handling the flood; add AWS WAF for the injection
Shield Standard is automatic and free for every customer. Only WAF needs adding.
- C

 Security groups for the flood; AWS Shield Advanced for the injection
Both halves wrong. Security groups cannot deny, and Shield never reads request content.
- D

 Amazon GuardDuty for both problems
A detection service. It would report both and block neither.

THE SIGNAL

Two problems at two layers, and the question also asks what they already have. Shield Standard is always already on.

A bank must store encryption keys in hardware that no other organisation shares, and its regulator requires the bank to demonstrate that AWS staff cannot access the key material under any circumstances.

A second team in the same bank simply needs to encrypt EBS volumes with keys it can audit.

Which two services meet these requirements? (Choose two.)

- ☐ A AWS KMS
- ☐ B AWS CloudHSM
- ☐ C AWS Certificate Manager
- ☐ D AWS Secrets Manager
- ☐ E AWS Systems Manager Parameter Store

◆ PAUSE AND DECIDE

Which two services meet these requirements? (Choose two.)

- A

AWS KMS
Encrypts EBS volumes with customer managed keys, and every key use is logged in CloudTrail.
- B

AWS CloudHSM
Single-tenant hardware under the bank's exclusive control. The only option meeting the regulator's demand.
- C

AWS Certificate Manager
TLS certificates for data in transit. Neither requirement is about traffic.
- D

AWS Secrets Manager
Stores and rotates credentials. It is not a key management service for volume encryption.
- E

AWS Systems Manager Parameter Store
Configuration storage. It uses KMS for encryption rather than replacing it.

THE SIGNAL

Two teams, two different needs. The regulator's wording forces CloudHSM; the ordinary need is satisfied by KMS.

An application reads a database password from a configuration file. Security policy now requires that the password changes every thirty days, that the change happens without a human editing anything, and that the application always retrieves the current value.

The database is Amazon RDS for MySQL.

Which service should the company use?

- ☐ A AWS Systems Manager Parameter Store
- ☐ B AWS Secrets Manager
- ☐ C AWS KMS
- ☐ D Amazon S3 with server-side encryption

◆ PAUSE AND DECIDE

Which service should the company use?

- A

AWS Systems Manager Parameter Store
The strongest distractor. It stores the secret securely and cheaply, but has no built-in automatic rotation.
- B

AWS Secrets Manager
Automatic rotation, with native support for RDS. It changes the password in the database and updates the stored secret.
- C

AWS KMS
Manages the keys that encrypt a secret. It does not store or rotate the secret itself.
- D

Amazon S3 with server-side encryption
Encrypted storage for a password file. Nothing rotates and nothing is purpose-built.

THE SIGNAL

Without a human editing anything is the rotation requirement in disguise. That single clause eliminates option A.

A company's public website went offline for two hours because a TLS certificate expired and nobody noticed the renewal reminder. The certificate was manually purchased and installed on an Application Load Balancer.

The company wants to make sure this cannot happen again.

What should the company do?

- ☐ A Set a CloudWatch alarm on the certificate expiry date
- ☐ B Use AWS Certificate Manager to issue and renew the certificate
- ☐ C Store the certificate in AWS Secrets Manager
- ☐ D Encrypt the certificate with AWS KMS

◆ PAUSE AND DECIDE

What should the company do?

- A

 Set a CloudWatch alarm on the certificate expiry date
Improves the reminder that was already ignored once. It still depends on a person acting in time.
- B

 Use AWS Certificate Manager to issue and renew the certificate
ACM renews automatically and deploys to the load balancer. The failure mode is removed, not monitored.
- C

 Store the certificate in AWS Secrets Manager
Storing it more securely does nothing about expiry. It will still expire on the same date.
- D

 Encrypt the certificate with AWS KMS
Confuses secrecy with validity. An encrypted expired certificate is still expired.

THE SIGNAL

Cannot happen again means eliminate, not monitor. Option A only makes the ignored reminder louder.

A company runs sixty AWS accounts under AWS Organizations. The security team has written a set of AWS WAF rules and needs every existing and future internet-facing application load balancer in every account to have them applied.

Teams create new accounts and load balancers regularly, without telling the security team.

Which service meets this requirement?

- | | |
|---|---|
| ☐ A Apply the web ACL manually in each account | ☐ B AWS Firewall Manager |
| ☐ C AWS Shield Advanced | ☐ D AWS Config |

◆ PAUSE AND DECIDE

Which service meets this requirement?

- A

 Apply the web ACL manually in each account
Fails on the last sentence. Resources appear without the security team knowing, so manual application will always lag.
- B

 AWS Firewall Manager
Applies WAF policies across an organisation, and new accounts and resources inherit them automatically.
- C

 AWS Shield Advanced
DDoS protection. It does not distribute WAF rule sets across accounts.
- D

 AWS Config
Would detect load balancers without a web ACL and report them. Detecting is not applying.

THE SIGNAL

Existing and future, across many accounts, without being told. Three clauses all pointing at Firewall Manager.

What to carry out of this module

- ◆ **Name the layer.** Volume is Shield, request content is WAF, instance or subnet is security groups and NACLs.
- ◆ Shield Standard is free and already on. Advanced costs \$3,000 a month and needs a stated reason.
- ◆ **KMS is the default for keys.** CloudHSM only when a regulator demands dedicated hardware.
- ◆ At rest means KMS. In transit means certificates and ACM.
- ◆ **Automatic rotation means Secrets Manager.** Free configuration storage means Parameter Store.

ON THE EXAM

Firewall Manager applies protections across accounts. It protects nothing by itself and needs AWS Organizations.